

Spring AI: Modül 11

**Üretim Güvenlik Korkulukları (Guardrails),
Güvenlik ve Gözlemlenebilirlik**

**Java ile Üretim Düzeyinde Güvenli Yapay Zeka
Sistemleri**

1. Kurumsal Yapay Zekada Güvenlik Tehditleri

- Kurumsal kullanıcılara açılan LLM sistemleri yeni güvenlik zafiyetleri barındırır:
 - **Prompt Enjeksiyonu (Prompt Injection) & Jailbreak:** Model talimatlarını manipüle edip sırları sızdırma.
 - **Kişisel Veri (PII) Sızıntısı:** Kredi kartı, TC kimlik ve sağlık verilerini dış model sağlayıcılarına gönderme.
 - **Kontrolsüz Token Maliyetleri:** Denetlenmeyen kullanıcı sorguları nedeniyle devasa faturalar oluşması.

2. Gelen ve Giden Güvenlik Korkulukları (Guardrails)

[Kullanıcı İstem Metni]



- 1. Enjeksiyon Dedektörü
- 2. Kişisel Veri (PII) Maskeleye

→ Jailbreak tespit edilirse ENGELLE
→ Kart ve Kimlikleri [REDACTED] ile gizle

(Temizlenmiş İstem)



[Spring AI Model Çağrısı]



- 3. Çıktı Doğrulayıcı

→ Halüsinasyon ve veri sızıntısı denetimi

3. Micrometer ve OpenTelemetry ile Gözlemlenebilirlik

- Spring Boot Actuator ve Micrometer ile tam entegrasyon:
 - `spring.ai.requests.total` : Toplam istek hacmi.
 - `spring.ai.security.injections.blocked` : Engellenen saldırı sayısı.
 - `spring.ai.inference.duration` : Yanıt süreleri ve gecikme dağılımları.
- Dağıtık izleme (tracing) kimlikleri Jaeger / Zipkin'e otomatik aktarılır.

4. Hız Sınırlama (Rate Limiting) ve Maliyet Denetimi

- Kullanıcı ve departman bazında bütçe limitleri uygulayın:
 - Saatlik maksimum token kotası.
 - Semantik önbellekleme (semantic caching) ile tekrarlayan maliyetleri sıfırlama.

5. Çıkarımlar ve İlkeler

1. İstemler VPC sınırlarını terk etmeden önce tüm PII verilerini maskeleyin.
2. Düşmanca enjeksiyon kalıplarını modele ulaşmadan önce filtreleyin.
3. Bütün yapay zeka çağrılarını sayaçlar, histogramlar ve dağıtık izleme ile gözlemleyin.